

ĐỀ THI KẾT THÚC HỌC PHẦN

Học kỳ 1, Năm học 2023-2024

Tên học phần: **Mật mã học**

Mã học phần: **NT219 (3TC)**

Thời gian làm bài: **75 phút**

Ngày thi: .../.../2024

Dành cho lớp NT219.O11.ANTN

Đề thi:

Câu 1. (4,0 điểm)

Phân tích tính hiệu quả của các hệ thống khoá công khai RSA và ECC (Mật mã đường cong Eliptic) về độ phức tạp tính toán, kích thước khoá và tỷ lệ giữa kích thước đầu ra và kích thước đầu vào trong cùng mức bảo mật. Dựa trên phân tích của bạn, hãy đề xuất thuật toán phù hợp cho giao tiếp trên các thiết bị di động và giải thích sự lựa chọn của bạn.

Câu 2. (3,0 điểm)

Cho giao thức trao đổi khoá ECDHE như sau:

Thiết bị di động

- Chọn đường cong ECC prime256v1 và điểm sinh G
- Tạo khoá bí mật m và khoá công khai $M = mG$
- Tính khoá phiên $SKey_M = m.S$

$(\text{prime256v1}, M) \rightarrow$

$\leftarrow S$

Máy chủ

- Tạo khoá bí mật s và khoá công khai $S = s.G$
- Tính khoá phiên $Skey_s = s.M$

Phân tích các điểm yếu của các giao thức trên, đặc biệt là các cuộc tấn công Man in the Middle (MITM). Đề xuất một phương án cải tiến tích hợp với giao thức trên để phát hiện, ngăn chặn hoặc giảm thiểu các cuộc tấn công MITM. Xem xét những đánh đổi hoặc thách thức có thể xuất hiện trong phương án cải tiến đề xuất, chẳng hạn như tác động đến hiệu suất tính toán, độ phức tạp của hệ thống, hoặc khó khăn khi triển khai trên hệ thống mạng lớn.

Câu 3. (3,0 điểm)

Một doanh nghiệp lớn có nhiều chi nhánh sử dụng dịch vụ đám mây để lưu trữ và chia sẻ dữ liệu dùng chung. Hãy đề xuất một phương án mã hoá tích hợp cho dịch vụ lưu trữ đám mây, đảm bảo tính bảo mật (confidential) và toàn vẹn (integrity) dữ liệu của dữ liệu. Phân tích phương án đề xuất về mặt bảo mật, hiệu quả tính toán và lưu trữ, quản lý khoá và các lỗ hổng tiềm ẩn.

--- HẾT ---

ĐÁP ÁN THAM KHẢO

Câu 1. (4,0 điểm)

Phân tích tính hiệu quả của các hệ thống khoá công khai RSA và ECC (Mật mã đường cong Eliptic) về độ phức tạp tính toán, kích thước khoá và tỷ lệ giữa kích thước đầu ra và kích thước đầu vào trong cùng mức bảo mật. Dựa trên phân tích của bạn, hãy đề xuất thuật toán phù hợp cho giao tiếp trên các thiết bị di động và giải thích sự lựa chọn của bạn.

	RSA	ECC
Độ phức tạp tính toán	- Tính toán trên các phép nhân, mũ, lũy thừa, module - Sử dụng bài toán phân tích số nguyên lớn thành 2 số nguyên tố - Độ phức tạp $O(n^3)$ với n là số bit của khoá - RSA yêu cầu nhiều tài nguyên tính toán hơn đặc biệt khi tạo khoá và giải mã	- Sử dụng đường cong elliptic. Độ khó của bài toán dựa trên bài toán logaric rời rạc trên đường cong elliptic. - Tính toán trên phép toán cộng và nhân. - Độ phức tạp $O(n^2)$ với n là số bit của khoá - ECC có hiệu suất cao hơn do các thao tác ít phức tạp hơn
Kích thước khoá	- RSA yêu cầu kích thước khoá lớn - RSA cần các khoá có kích thước lớn để an toàn trước các cuộc tấn công (tối thiểu 3072 bit)	- ECC 256 bit tương đương RSA 3072 bit. ECC cần số bit cho khoá ít hơn nhiều. - Kích thước khoá nhỏ giúp giảm bớt lượng dữ liệu cần xử lý và lưu trữ.
Tỷ lệ kích thước đầu ra và kích thước đầu vào	- Input phụ thuộc vào key. - Output phụ thuộc key.	- Input phụ thuộc vào PK. - Output nhỏ hơn nhiều so với input ECC trở nên hiệu quả hơn về mặt băng thông và lưu trữ.

Thuật toán phù hợp trên các thiết bị di động:

ECC là lựa chọn phù hợp hơn cho giao tiếp trên các thiết bị di động vì:

- Với RSA, trên các thiết bị di động có dung lượng hạn chế thì khoá lớn có thể gây ra vấn đề về hiệu suất và tiêu thụ năng lượng.
- ECC với khoá nhỏ và các phép toán hiệu quả, nó cung cấp mức độ bảo mật cao hơn với yêu cầu tài nguyên ít hơn so với RSA.

Tóm lại ECC vượt trội hơn RSA trong hầu hết các tiêu chí về hiệu suất, kích thước khoá cũng như bảo mật khi áp dụng cho các thiết bị di động.

Câu 2. (3,0 điểm)

Cho giao thức trao đổi khoá ECDHE như sau:

Thiết bị di động

- Chọn đường cong ECC prime256v1 và điểm sinh G
- Tạo khoá bí mật m và khoá công khai $M = mG$
- Tính khoá phiên $SKey_M = m.S$

$\xrightarrow{\text{(prime256v1, M)}}$

Máy chủ

- Tạo khoá bí mật s và khoá công khai $S = s.G$
- Tính khoá phiên $Skey_s = s.M$

$\xleftarrow{S}$

Phân tích các điểm yếu của các giao thức trên, đặc biệt là các cuộc tấn công Man in the Middle (MITM). Đề xuất một phương án cải tiến tích hợp với giao thức trên để phát hiện, ngăn chặn hoặc giảm thiểu các cuộc tấn công MITM. Xem xét những đánh đổi hoặc thách thức có thể xuất hiện trong phương án cải tiến đề xuất, chẳng hạn như tác động đến hiệu suất tính toán, độ phức tạp của hệ thống, hoặc khó khăn khi triển khai trên hệ thống mạng lớn.

Phân tích điểm yếu của giao thức trên:

- Không đảm bảo tính toàn vẹn dữ liệu: dữ liệu trong quá trình truyền đi hoàn toàn có thể bị thay đổi (đặc biệt MITM: tấn công MITM là một trong những điểm yếu chính của giao thức Diffie-Hellman. Trong kiểu tấn công này, một kẻ tấn công có thể chặn các thông điệp trao đổi giữa hai bên và giả mạo để thiết lập hai khóa bí mật khác nhau với mỗi bên. Kết quả là, kẻ tấn công có thể giải mã và chỉnh sửa tất cả các thông điệp trao đổi giữa hai bên mà không bị phát hiện.), mà cả 2 bên đều không hay biết.
- Không có xác thực người gửi và người nhận: Diffie-Hellman chỉ đảm bảo việc thiết lập khóa chung mà không cung cấp cơ chế xác thực danh tính của các bên tham gia.
- Việc chọn các tham số thiết lập không an toàn.
- Nếu các khóa phiên không được tạo lại thường xuyên, một khi khóa bí mật bị lộ, tất cả các phiên trước đó đều có thể bị giải mã.

- Vấn đề triển khai: Triển khai đúng đắn giao thức ECDHE đòi hỏi kiến thức sâu rộng về mật mã học và cài đặt chính xác các tham số ECC.

Đề xuất phương án cải tiến:

1. Sử dụng cơ chế xác thực người dùng:
 - a. Dừng Chứng chỉ số (Digital Certificate) – cung cấp cơ chế xác thực mạnh mẽ, đảm bảo các bên tham gia không bị giả mạo. (Thách thức: việc triển khai và quản lý PKI có thể phức tạp và tốn kém)
 - b. Dừng chữ ký số: cung cấp cơ chế xác thực và đảm bảo tính toàn vẹn dữ liệu tuy nhiên nó có thể ảnh hưởng đến hiệu suất.
2. Sử dụng kết hợp với giao thức TLS/SSL: ECDHE thường được sử dụng trong giao thức TLS/SSL để cung cấp bảo mật trong truyền thông mạng. TLS/SSL cung cấp cơ chế xác thực hai chiều và bảo vệ chống lại tấn công MITM. (đòi hỏi cấu hình và quản lý chứng chỉ đúng cách)
3. Thực hiện xác thực 2 yếu tố: Tăng độ phức tạp và thời gian xác thực, có thể ảnh hưởng đến trải nghiệm người dùng.

Câu 3. (3,0 điểm)

Một doanh nghiệp lớn có nhiều chi nhánh sử dụng dịch vụ đám mây để lưu trữ và chia sẻ dữ liệu dùng chung. Hãy đề xuất một phương án mã hoá tích hợp cho dịch vụ lưu trữ đám mây, đảm bảo tính bảo mật (confidential) và toàn vẹn (integrity) dữ liệu của dữ liệu. Phân tích phương án đề xuất về mặt bảo mật, hiệu quả tính toán và lưu trữ, quản lý khoá và các lỗ hổng tiềm ẩn.

Phương án mã hoá an toàn dựa trên các nguyên tắc sau:

1. Mã hoá đầu cuối: E2EE: mã hoá dữ liệu ở end-user trước khi gửi lên đám mây và chỉ giải mã ở thiết bị người dùng khác khi cần truy cập. Đảm bảo dữ liệu luôn ở bản mã trong suốt quá trình lưu trữ và truyền tải.
- Sử dụng mã hoá đối xứng AES-256 để mã hoá dữ liệu và RSA/ECC để mã hoá khoá cho AES.
2. Quản lý khoá an toàn và phân cấp: sử dụng hệ thống quản lý khoá phân cấp để dễ quản lý và phân phối. Mỗi chi nhánh có 1 khoá chính riêng và mỗi file có 1 khoá mã hoá riêng biệt. Có thể sử dụng AWS KMS hay Google Cloud KMS
3. Sử dụng các cơ chế bảo mật cho giao tiếp: Mã hoá mọi giao tiếp giữa người dùng và dịch vụ đám mây bằng TLS/SSL để đảm bảo khỏi cuộc tấn công MITM. (TLS 1.2 trở lên)
4. Xác thực dữ liệu: sử dụng HMAC với SHA256 để đảm bảo tính toàn vẹn dữ liệu.
5. Kiểm soát truy cập người dùng: ai có quyền làm gì, sửa gì trong hệ thống. (RBAC – MFA)

Phân tích phương án:

1. Về mặt bảo mật:

a. Ưu:

- Dữ liệu được mã trong quá trình truyền và lưu nên ai có quyền mới được giải mã và truy cập.
- Sử dụng TLS/SSL bảo vệ dữ liệu trong quá trình truyền
- Quản lý khoá và bảo vệ hiệu quả.
- Sử dụng HMAC để đảm bảo toàn vẹn dữ liệu

b. Nhược:

- Hệ thống quản lý khoá bị xâm phạm, toàn bộ hệ thống có thể bị phá vỡ.
- Yếu tố con người, như mất khoá, quản lý mật khẩu có thể dẫn đến các lỗ hổng.

2. Hiệu quả tính toán và lưu trữ

a. Ưu điểm:

- AES-256 là thuật toán mã hóa mạnh mẽ và hiệu quả, có thể được tối ưu hóa trên nhiều nền tảng.
- TLS/SSL là chuẩn bảo mật đã được tối ưu hóa cho hiệu suất truyền tải dữ liệu.
- Hệ thống quản lý khóa phân cấp giúp giảm thiểu gánh nặng quản lý khóa cho người dùng.

b. Thách thức:

- Mã hóa dữ liệu đầu cuối và việc giải mã trên thiết bị người dùng có thể tăng tải tính toán và tiêu thụ năng lượng, đặc biệt là trên các thiết bị di động.
- Việc duy trì và bảo vệ hệ thống quản lý khóa có thể đòi hỏi tài nguyên và chi phí quản lý.